

A Human-AI Assisted Methodology for the Generation of a Cybersecurity Controls Library

Tiziano Sammarone

Sapienza University of Rome, Rome, Italy
sammarone.1798569@studenti.uniroma1.it

Marco Angelini

Link University of Rome, Rome, Italy
m.angelini@unilink.it

Abstract—Security frameworks are important tools to govern organizations’ cybersecurity, but their creation and update require significant time and human effort to avoid leaving organizations with fragmented regulations. This work proposes a methodology to use Generative AI to assist the risk assessor, using AI to analyze documents and recommend useful excerpts, transforming them into controls and assisting in results review. The methodology was validated over 55 documents, half of which were analyzed by a human expert, with the results compared using the AI model to tune it. The second half is analyzed by the model, and the expert reviewed the results. The AI provides a degree of confidence in the analysis and automatically annotates the document excerpts. These tests demonstrated comparable accuracy and a significant reduction in analysis time. Two controls libraries were generated as case study. One for the NIST Cybersecurity Framework 2.0 regarding cybersecurity of generative AI, the other for the NIS 2 directive.

Index Terms—Cyber Risk Assessment, Generative AI, Human-Centered AI, LLM, Cybersecurity Framework

I. INTRODUCTION

Cybersecurity is critical for organizations, and a fundamental activity to perform is the cybersecurity risk assessment. To secure their productive processes and systems, an organization needs to consider and apply security controls, which require intensive work to be extracted and modeled. To do so, it is necessary to study in depth the documentation that handles cybersecurity for the specific domain, and from it, identify and extract relevant excerpts. These are then to be transformed into actionable controls. For an organization, it is costly to apply this full process, as it takes a significant amount of time and resources, for all the times it must be applied and updated to keep pace with the evolution of cyber threats. These problems worsen in case of rapidly evolving technologies like Artificial Intelligence (AI), which offers important benefits, at the price of correctly handling the risks of biases and errors [16]. Organizations rely on external governance tools, such as cybersecurity frameworks or regulations. A framework is a collection of guidelines and best practices to help organizations better manage and reduce cybersecurity risks¹. While these tools already exist [22], they are fragmented, prone to human errors, and slow to adapt. For example, the frameworks require years to be updated. Also, like in the case of the EU AI Act², they do not provide details on implementing security controls. The primary contribution of this work is a methodology to use Generative AI as an assistant for the human assessor in the processes necessary to develop and

update a library of cybersecurity controls using standard frameworks, assisting in the analysis of a large quantity of documents, extracting and mapping the relevant excerpts and related actionable controls. With the current state of the art, this process is done manually by human experts, presenting several limitations. First, a high amount of time and human effort is required, especially for tasks like the analysis of a large number of documents. Second, the process is prone to error and human biases, as it depends entirely on the ability and knowledge of the experts. Consequently, this kind of work is challenging to scale and reproduce. Some new methods include the exclusive use of AI models for this work. Mahadevkar et al. [10] explores the advantages of using AI to analyze unstructured data compared to traditional methods. But this also presents limitations. First, there is the possibility that the AI shows undesired behaviors, like hallucinations, lowering the quality of the results. Second, the process is not transparent, biased by AI, and difficult to attribute in case of problems. The methodology proposed by this work aims to overcome these limitations, join the human expert and the AI model, and use the latter to assist the former. The AI model reduces the amount of time needed for onerous tasks like document analysis, using its capabilities to scale the analysis, while the proposed methodology provides guarantees on accuracy and communication of uncertainty. The risk assessor expert has the task of supervising the AI work, leveraging provided uncertainty, reviewing the results, and ensuring the quality at each stage of the process, saving time and resources by focusing on a reduced number of critical cases. To demonstrate the application of this methodology, we developed two case studies: the first on creating a NIST cybersecurity framework 2.0 controls library for the secure deployment of generative AI. The second case study is the creation of a controls library from the EU NIS 2 directive³. Summarizing, this paper contributes:

- A methodology to use Generative AI to assist human experts in the creation and update of cybersecurity controls libraries mapped on standard frameworks.
- The validation of the methodology, with quantitative evaluation used to tune the AI model, and replicable for a generic domain
- Two case studies, A NIST Cybersecurity Framework 2.0 controls library for securing Generative AI, and a controls library for the EU NIS 2 European directive, showing the applicability in real scenarios

This document presents the following structure: Section II presents the state of the art; Section III describes in detail the

¹NIST, “NIST Cybersecurity Framework 2.0”, 2024

²European Union, “The EU Artificial Intelligence Act”, 2024.

³European Union, “NIS 2 directive”.

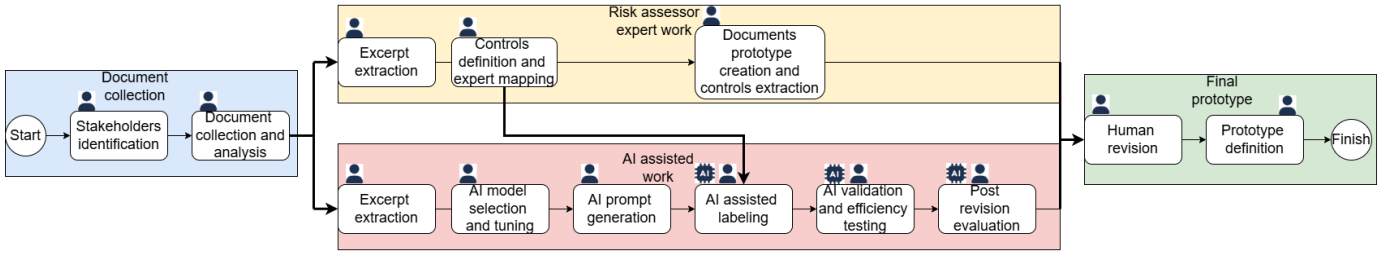


Fig. 1. Phases of the work of methodology development

developed methodology and the steps that compose it; Section IV describes the validation of the methodology and the results of its application to two case studies. Section V concludes the paper.

II. RELATED WORK

Extracting cybersecurity controls and aligning them with established frameworks has been previously documented [8], [5]. However, these approaches primarily involve manual processes and do not address AI support. Generative AI applications span numerous domains [15], particularly in risk analysis and assessment [2], [19], financial industries [17], autonomous vehicle technology [1], and construction management [21]. Examining specific research contributions to support cybersecurity, Obisesan [14] examines AI applications for implementing cybersecurity framework controls within e-commerce. Mahadevkar et al. [10] investigate the benefits of AI-driven unstructured data analysis versus conventional methodologies. Chandrasekaran [6] evaluates how Generative AI can enhance effectiveness and efficiency in Governance, Risk Management, and Compliance processes. Roshani et al. [18] examine Generative AI implementation for delivering individual patient risk assessments in healthcare. These papers highlight AI's potential for enhancing risk management and operational workflows. Contrary to our approach, they rarely focus on supporting the human, but focus more on the pure automatic application of AI. Complementary research has focused on Generative AI vulnerabilities and security challenges. Hu¹ examines how poisoning attacks can undermine deep learning model classification integrity, while proposing defensive strategies. Li et al. [9] demonstrate privacy vulnerabilities associated with application-integrated LLMs, presenting evidence of risks when private information is incorporated into model training datasets. Zou et al. [27] demonstrate techniques for bypassing content generation safeguards in LLMs through adversarial attacks, enabling automated production of problematic content. Teo et al. [26] address concerns including data privacy vulnerabilities, poisoning attack vectors, bias propagation, and hallucinations, while proposing risk mitigation approaches and examining AI applications for cybersecurity. NIST has developed a dedicated AI risk management framework (RMF)² and its corresponding profile [13], which represents an implementation of AI RMF functions, categories, and subcategories tailored to the Generative AI domain. Mauri and

Damani [11] present a modified version of Microsoft's STRIDE methodology adapted for Machine Learning (ML) applications, creating connections between potential ML failure scenarios, threat vectors, and compromised security properties. Vadisetty and Polamarasetti [23] introduce a Generative AI-driven distributed cybersecurity framework designed to improve threat detection and response capabilities within AI-integrated data ecosystems. In contrast to our approach, their methodology employs AI to enhance the framework through cyber-attack simulation, anomaly detection, and adaptive countermeasure generation, whereas our work utilizes AI to assist in the document analysis and security control extraction and provide a more comprehensive controls library for securing generative AI. Verma et al. [24] analyze opportunities and risks associated with AI, including challenges in identifying and addressing threats originating from AI-generated content. Wan et al. [20] develop a collection of security benchmarking tools for LLMs to evaluate cybersecurity vulnerabilities and capabilities, detailing their application to LLMs. Khan et al. [7] and Morovat and Panda [12] analyze the advantages offered in using AI in cybersecurity, the present state of its application, and the need to improve the use of this technology to adapt to the modern cybersecurity scenario. While all these works demonstrate that the use of Generative AI in cybersecurity is widely recognized as advantageous, they primarily focus on technical activities. Instead, our work explores the use of AI in a proactive manner, by generating a control library as a preventive measure, offering aid in the cybersecurity governance process.

III. METHODOLOGY

The objective is to realize an AI-assisted methodology to help the expert create or update a controls library mapped to a standard framework. While the methodology is general, for each phase, the work done for a specific domain, securing Generative AI, is reported, providing concrete examples and quantification. Figure 1 presents the conceptual diagram of the proposed methodology, showing its phases and the way these interact with each other.

A. Document collection

The first phase is the definition of the objectives and collecting all the necessary material to reach them. So, this phase starts with the stakeholder identification and the collection of the related documents. It is important to collect documents of different kinds from different sources to address all important aspects of the domain. Then, there is the necessity to choose the proper framework. To avoid gaps in key concepts, three important frameworks are considered in this

¹Hu, Charles and Hu, Yen-Hung Frank, "Data Poisoning on Deep Learning Models", 2020.

²NIST, "Artificial intelligence risk management framework", 2023.

work. The “NIST Cybersecurity Framework 2.0”¹ is the main framework used. The other two are the Italian “National Framework For Cybersecurity and Data Protection” [3], and the “NIST privacy framework”², used for excerpts about privacy and transparency.

1) *Stakeholders identification*: For the domain at hand, the expert must define the stakeholder who will be the target for the controls library (e.g., an organization, a service provider, etc.). For example, if the controls library and mapping are targeted at the security of Generative AI, four categories of stakeholders can be identified: the developer, the subject responsible for developing a Generative AI system; the deployer, the entity responsible for offering an AI service to third parties; the user, the subject who acquire and use Generative AI systems into their organization. Finally, the Decision-maker/Legislator is the subject with the power to decide laws and norms that affect Generative AI systems.

2) *Document collection and analysis*: A substantial collection of documents must be gathered, looking at regulations, standards, and best practices, to ensure as wide coverage as possible of the target field. For secure Generative AI, 55 documents were finally collected (full list available in supplemental materials), with this activity requiring one and a half months. Different attributes categorize these documents, which are provenance (International or European), country, association, typology (best practice, norm, standard), date, core topics, size (in pages), and format (strongly structured, mildly structured, poorly structured). The document collection used different techniques to ensure a wide coverage, which led to the collection of a corpus of 75 documents. We used keyword search, made by inserting the core topics’ words, such as “AI risk management” and “AI security”. Then, specific keywords were combined with specific names of countries and organizations such as “OWASP AI”. Then, snowballing was applied to the retrieved bibliography. The work was considered comprehensive when the relevant reference links started to point to already collected documents. 20 documents initially considered were excluded, mainly because they were too old or less pertinent to our scope.

B. Risk assessor expert work

This phase aims to manually analyze half of the collected documents, with identified excerpts used as a test set for the results of the following AI analysis. So, from the document, it is necessary to identify the excerpts that mention security topics, and from them, it is necessary to extract and define the related security controls. The excerpts then need to be mapped to the chosen framework. This phase was fully executed by the risk assessor expert and required approximately five and a half months.

1) *Excerpts extraction and mapping*: Thirty of the collected documents were manually analyzed, reading each page of the considered document, and when an action, recommendation, best practice, guideline, tip, norm, or standard about AI was identified, the text was extracted. Each excerpt was characterized by a set of attributes: theme, the major target (principal stakeholder), the section (in which the excerpt is presented), and the excerpt text itself. Then, three attributes modeled the related subcategories of

the framework to which the excerpt may be mapped. The chosen subcategories are a maximum of three for each extract, ordered from the most relevant to the least. Sentences with generic content or without applicable measures were excluded.

C. AI assisted work

This phase follows these steps: identify the right model for the scope, create a prompt to effectively use the model, and then test the results, before using the AI to analyze part of the collected document set. The test set of manually analyzed documents is matched with the results of the AI analysis. The objective is to obtain an AI model and a prompt tested and validated for the document analysis, before it can analyze the second half of the document set.

1) *AI model selection and tuning*: To select the most suited AI model, their ability was evaluated, in particular their document analysis capability, their versatility (the ability of the model to adapt efficiently to task-tailored requests), and their veridicality, which represents the correctness of the answer (presence of biases or hallucinations). This evaluation led to the exclusion of various models for their inability to adapt to tailored requests, and to the exclusion of models like ChatGPT for the excessive amount of hallucinations in answering. The chosen model was “Claude” by Anthropic³.

2) *AI prompt definition*: Prompt creation strategy and related work were studied to create an efficient prompt. Chain-of-thought [25] was used, which is an approach that splits an elaborate problem into intermediate steps. It also allows the insertion of positive and negative examples for the model to better understand the desired results. The prompt presents the following structure:

- Task block: The first block regards the high-level task to be done and contains instructions on how to do it, like formatting and the attributes of the excerpts. At the end, it contains positive examples.
- Concept blocks: These are various blocks, each containing the core topics of the domain under analysis (in our case, secure Generative AI). There are also positive examples of relevant excerpts to capture. These blocks are independent of each other, so blocks with different arguments for the analysis can be added or removed freely. The final prompt uses 12 different modules.
- Refinement block: This final block contains refinement on the results produced by the previous blocks (e.g., asking the model not to add parts of the prompt in the answer, and to check the completeness of the answer). It also produces and updates the final output file with updated results in a specific format.

3) *AI driven document analysis*: Each document is analyzed by the model with the developed prompt. The output of this operation is the set of relevant excerpts of the document. As this is not a fully automated methodology, the expert needs to review the results of the analysis to exclude useless excerpts and check for missed relevant ones. In this revision, the expert is aided by the AI model. First, after the analysis, the model is tasked to give a confidence degree for each identified excerpt, representing an evaluation of how much the model is sure that it is relevant to the analysis scope.

¹NIST, “NIST Cybersecurity Framework 2.0”, 2024.

²NIST, “NIST Privacy Framework”, 2020.

³Anthropic, “Claude”, version “3.5 Sonnet”

The degree is represented by a three-tier qualitative classification: high, medium, and low. Also, the model is asked to give the excerpt a label that identifies it as more of a “definition” than an actionable control. This has the objective of making the revision work easier. The risk assessor can decide to review only less confident excerpts, while automatically including or excluding all those marked with a specific confidence degree. A second aid is given by asking the AI model to annotate the excerpts directly on the document using different colors, based on their confidence degree. This allows the expert to only focus on the parts of the document that the AI did not consider (all the unannotated ones) to check for missing excerpts. Furthermore, external aid is provided to the expert to easily check the analysis performance using two external scripts. The first one takes as input the file that the model gives as output and shows the total number of found excerpts, their distribution by the framework’s mapping, and two graphs that show the distribution of excerpts by confidence degree, and how many are labeled as definitions. The second script is meant to compare two files: the expert analysis results and the AI analysis results, using the same format. This script gives back the number of true positives, false negatives, and false positives, using a similarity match to compare the excerpts of the two files. These are shown textually and in a confusion matrix. Then, four graphs show the relation in percentage between useful and useless excerpts, grouped by confidence degree and definition label. The last two graphs are the same as the first script. This is meant to offer a visual aid through an easy-to-execute script and an intuitive interface, to aid the expert in verifying the model behavior and the efficacy of the methodology during the analysis.

D. Controls library mapping

It is necessary to review the methodology results, and then it is possible to define the final mapping. To do so, we leverage the framework contextualization prototype format.

1) *Documents prototype creations*: First, each excerpt is analyzed, and from it, one or more controls are defined. A control is a self-contained text, describing an actionable security check that is homogeneous and can be immediately checked. From the excerpts, each single document part was associated with classes and priority levels for each subcategory of the chosen framework. There are three class levels: Free, which provides no controls, Recommended, which presents controls recommended for a correct cyber risk posture, and Mandatory, which presents controls from legally binding documents. The priority levels are also divided into three, based on the proportion between the cost of implementation and the risk reduction: low (low risk reduction or high costs), medium (good risk reduction or cheap cost), and high (important risk reduction regardless of the cost). The subcategories with the “Mandatory” class present High priority levels, as these have to be implemented in any case.

2) *Final prototype: AI user*: The process to create the final prototype was conceptually simple, asking to aggregate the results executed for each document, i.e., the related class and priority level for each document in the analyzed set. From this, a risk-based approach was chosen to decide the final class and priority level for each subcategory. The highest class and priority level were chosen for the final prototype. Together with this labeled framework core comes the implementation guide. This supplementary document

contains all the controls grouped by the framework’s subcategories. Under each subcategory, it is possible to see the list of related controls and the document from which they are taken. Together, they constitute the framework ready to be used for cyber risk assessment.

E. Collaborative Human-AI Workflow

Within this methodology, the human expert and AI model collaborate for document analysis and excerpt extraction. The expert guides the process by selecting documents and defining the analysis scope, while the AI performs the analysis and provides the excerpts list. The AI assists review through color-coded annotations and confidence degrees, enabling the expert to focus on uncertain cases while efficiently validating high-confidence results. This creates a collaborative workflow where the risk assessor guides the AI analysis and refines the results, while the AI capabilities scale the expert capacity. At the end, the expert transforms the excerpts into actionable controls.

IV. VALIDATION

The methodology is established to bring the following benefits to the document analysis and the controls library and mapping creation: a considerable saving of time compared to the only-risk assessor expert work, results qualitatively comparable to human work, and an aid in assisting the expert during the AI results revision. Table I summarizes the benefits and the phases contributing to them.

TABLE I
WORK’S PHASES CONTRIBUTION TO THE CONTRIBUTION HYPOTHESIS

Hypothesis (Compared to expert-only analysis)	Phases
H1: Acceptable quality, comparable with the expert analysis	AI model selection and tuning AI prompt generation Controls definition and expert mapping AI validation and efficiency testing Post-revision evaluation
H2: A considerable amount of time saved compared to the expert-only analysis	AI model selection and tuning AI prompt generation AI assisted labeling
H3: Assistance from the AI in results revision by estimation of confidence degree	AI prompt generation AI assisted labeling Post-revision evaluation

All the materials, including the prototype itself, the prompts used, the resulting files from the AI analysis, and the validation results are presented in a dedicated repository ¹.

A. H1: Validation of AI analysis results match with expert ones

The methodology is validated by comparing the results obtained by the AI with those obtained by the expert analysis. To do this, the set of 55 collected documents was divided: 30 were manually analyzed by the expert, while the remaining 25 were analyzed by the AI model. To make this process fair and comparable, the division respected an even distribution with respect to document type, size, and their level of structure. The expert-analyzed group of documents was re-analyzed by the AI model, and the results were compared.

¹<https://github.com/XAIber-lab/Human-AI-Assisted-Cybersecurity-Controls-Library-Generation.git>

For each document, at the end, the following data are available: Number of excerpts (AI and manual), true positive (excerpts present in both analysis and useful excerpts found by the AI), false positive (useless excerpts found by the AI), and false negative (useful excerpts not found by the AI). With these data, it was possible to compute the analysis of recall and precision metrics. With a good recall, the expert is sure the analysis captured the majority of what the document has to offer. With good precision, the expert is sure that the majority of what is present in the analysis result is relevant. The obtained values are 0,70 recall and 0,76 precision, so the AI work's efficacy is comparable to the expert work. Figure 2 shows the values of recall and precision for each document.

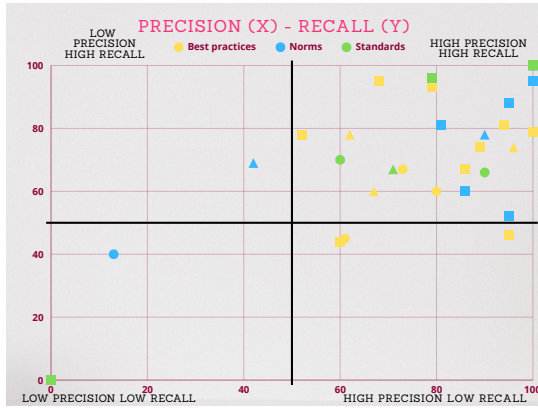


Fig. 2. Expert results scheme with documents grouped by format and typology, Square=Strongly structured, Triangle=Mildly structured, Circle=Poorly structured

B. H2: Validation of AI analysis results efficiency

For this validation, the second half of the document set is analyzed by the AI, and the results are checked by the risk assessor expert. The output of this operation is the set of relevant excerpts of the document, with the page from which they are taken, plus the confidence degree for each extract, and a new PDF with the found excerpts highlighted. This was done for the second set of 25 documents. Figure 3 shows the values of recall and precision for each document (computed after human revisions), each identified by a different figure and color based on its typology and structure.

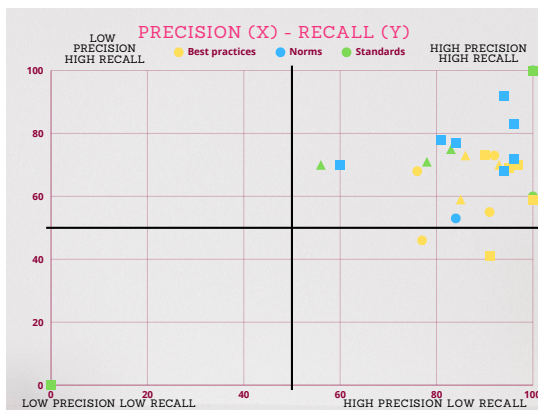


Fig. 3. AI results scheme with documents grouped by format and typology, Square=Strongly structured, Triangle=Mildly structured, Circle=Poorly structured

The final value obtained by the analysis of these 25 documents is good as the test set, with an even better precision value of 0,85

(previously 0,76), and a similar recall value of 0,69 (previously 0,70). For a single document, the manual analysis would have required two to four times the time needed by the AI-assisted analysis to complete the task. Considering also the various tasks done in parallel for this work, the time saved resulted in a difference of five months to analyze the first 30 documents manually, to one month for the AI-assisted analysis of the remaining 25 documents. Both the test phase and the AI-assisted analysis show a good quality for this kind of task. The precision is good, saving time for the analyst to review the results, and the recall is good enough to catch the large majority of the document's relevant contents, reducing the effort by approximately 2/3. These results show that the methodology brings an important saving in time with comparable quality, with the human expert accelerating their work on 70% of the work, with the remaining 30% to be done manually but with clear identification where to focus in the annotated documents.

C. H3: Validation of AI confidence degree results

The results of the AI-generated confidence degree were analyzed. When the AI marks an excerpt as high confidence, it is useful around 90,8% of the time, 70% if marked as medium confidence, 42,3% if marked as low confidence, and 28,2% if marked as "definition". Figure 4 summarizes the excerpts' usefulness.

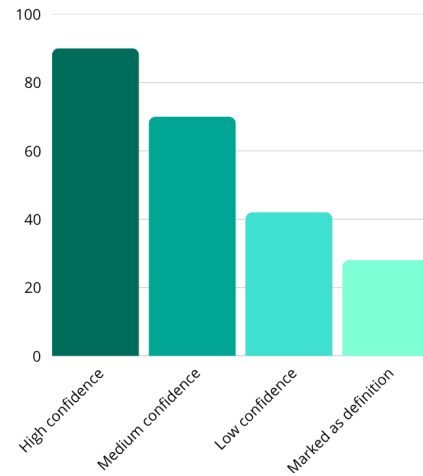


Fig. 4. Percentage of useful excerpts grouped by labels

Results confirm the utility of the confidence degree. Excerpts marked as high confidence are often useful, while the ones marked as "definition" are often useless. This helps the risk assessor expert to decide on which excerpt to focus more on during the revision of the AI-analysis results. We provide two web-based summary results obtained by launching scripts to help the expert review the results of the AI-assisted analysis. An example is visible in Figure 5.

D. Case study 1: AI user contextualization prototype

From all the excerpts of the manual and AI-assisted analysis, approximately 3750 controls were defined. The final framework contextualization prototype for the AI user is composed of 68 mandatory classes, 58 recommended classes, 73 high-priority levels, 4 medium-priority levels, and 51 low-priority levels. This

CSV Visualization

Total number of excerpts: 241

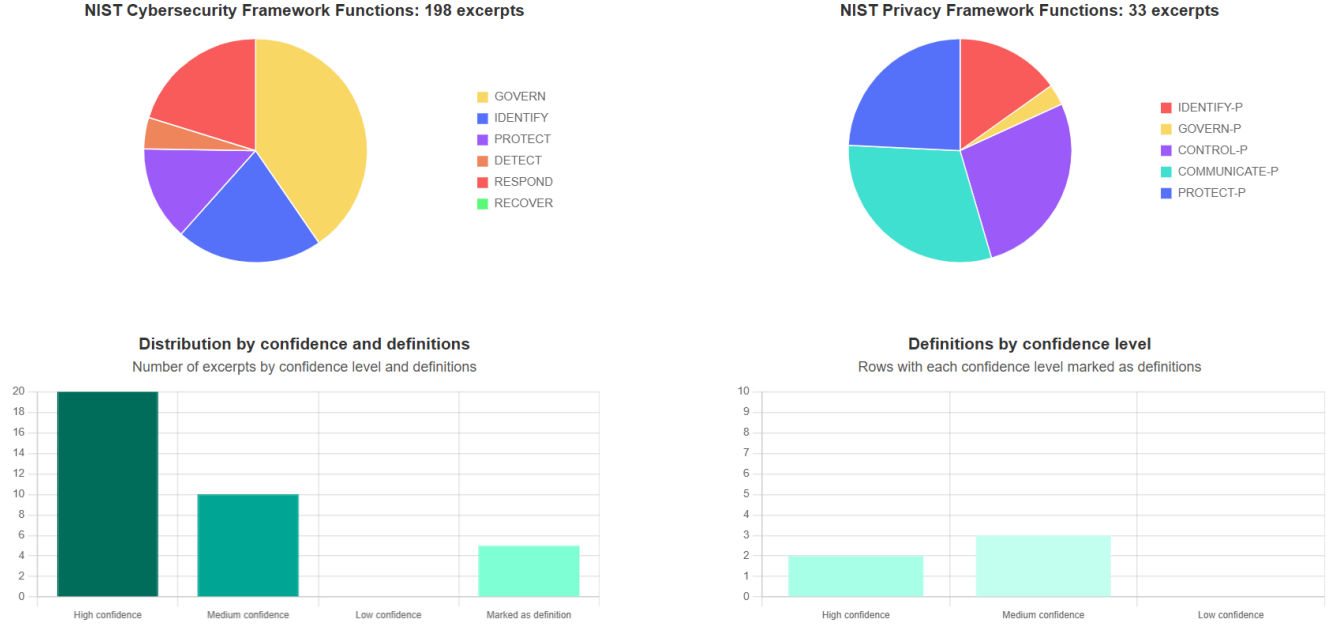


Fig. 5. Web-based summary of the analysis results of the EU NIS 2 directive

shows good coverage of the Generative AI security by the existing documentation, making this prototype useful for securely deploying AI. All the defined controls are grouped by subcategories. Figure 6 shows the number of controls for each function of the NIST 2.0 Cybersecurity framework. The prevalence of controls belongs

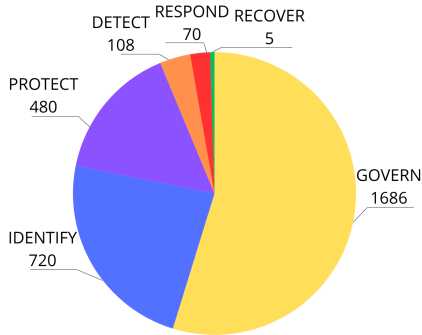


Fig. 6. Controls distribution by NIST framework's functions

to the new GOVERN function, followed by the IDENTIFY and PROTECT; DETECT and RESPOND contain fewer controls. The RECOVER function has almost no controls.

E. Case study 2: EU NIS 2 control library generation

The methodology was applied to generate a control library for the EU NIS 2 directive. The document was given to the AI model with the developed prompt and the NIST Cybersecurity Framework 2.0 core as the target. The output consisted of the relevant excerpts about cybersecurity, with the mapping proposals, the confidence

degree, and a label indicating if those excerpts were related to data protection. These last excerpts were mapped to the NIST privacy framework. The process took less than an hour, resulting in a file with the excerpts mapped to the two frameworks. The human expert revision (lasting an additional three days to complete the work) results indicate a precision of 91,34% and a recall of 80,19%, confirming the validity of the methodology. Then, 237 controls were defined. Figure 5 shows a summary of the analysis results, obtained through an interactive web-based environment, inspired by similar efforts for cybersecurity [4], we developed to support the analyst in evaluating the results and their quality.

V. DISCUSSION AND CONCLUSION

This work developed an AI-assisted methodology to aid humans in processes to create or update cybersecurity governance tools based on standard frameworks. The methodology has been created following the domain of secure generative AI, providing general steps applicable to any domain of interest. It has been validated quantitatively by reporting its accuracy and qualitatively through two case studies in real scenarios. We proved the efficacy of the methodology in mitigating the problems of human-only and AI-only work. Our methodology achieved a considerable saving of time (from two to four times), preserving quality (high precision and recall values), less dependent on the expert's ability, compared to the human-only work. The methodology allows for a simple use of the AI abilities for the analysis, without delegating the whole work to it, and provides aid to the human expert in monitoring the model behavior and revising its output, keeping the number of elements to revise low and manageable, overcoming the limitations of an AI-only work. The responsibility remains attributed to the

expert in case of problems, with a transparent process available. As this is a human-AI assisted methodology, the risk assessor expert retains legal accountability and responsibility for the entire process. As highlighted in Section III-E, the human is never substituted by the AI but is assisted by it during the task. The AI model provides aids to support the human in process oversight, emphasizing the importance of having the expert in charge of the process and responsible for results review. The methodology incorporates several safeguards to ensure accountability: the AI provides confidence degrees for each excerpt, enabling the expert to identify potentially unreliable results; all AI outputs require human validation before inclusion in the final controls library, and the transparent process allows for full traceability of decisions. Therefore, the developed methodology can be applied in real-world cybersecurity contexts while respecting the legal and ethical requirements of AI use, as mandated by legal documents such as the EU AI Act¹ and standardization documents like NIST Special Publication 1270². This work presents possibilities for improvement. The AI model was used to analyze the document set and support their revision, but other steps were done manually. The use of an integrated platform may improve the experience. Also, the accuracy of AI results is improvable, by applying refined models or prompting techniques.

ACKNOWLEDGMENT

This work has been supported by the European Union's Horizon Europe Resilient Trust project under grant agreement No 101112282.

REFERENCES

- [1] Abbaspour, A., Arab, A., Mousavi, Y.: Enhancing autonomous driving safety analysis with generative ai: A comparative study on automated hazard and risk assessment (2024), <https://arxiv.org/abs/2410.23207>
- [2] Al-Mhdawi, M., Qazi, A., Alzarrad, A., Dacre, N., Rahimian, F., Buniya, M.K., Zhang, H.: Expert evaluation of chatgpt performance for risk management process based on iso 31000 standard (2023), https://papers.ssrn.com/sol3/papers.cfm?abstract_id=4504409
- [3] Angelini, M., Ciccotelli, C., Franchina, L., Marchetti-Spaccamela, A., Querzoni, L.: Italian national framework for cybersecurity and data protection. In: Antunes, L., Naldi, M., Italiano, G.F., Rannenber, K., Drogkaris, P. (eds.) *Privacy Technologies and Policy*. pp. 127–142. Springer International Publishing, Cham (2020)
- [4] Angelini, M., Lenti, S., Santucci, G.: Crumbs: A cyber security framework browser. In: 2017 IEEE Symposium on Visualization for Cyber Security (VizSec). pp. 1–8 (2017). <https://doi.org/10.1109/VIZSEC.2017.8062194>
- [5] Carello, M.P., Marchetti-Spaccamela, A., Querzoni, L., Angelini, M.: Sok: Cybersecurity regulations, standards and guidelines for the healthcare sector *. In: 2023 IEEE International Conference on Intelligence and Security Informatics (ISI). pp. 1–6 (2023). <https://doi.org/10.1109/ISI58743.2023.10297246>
- [6] Chandrasekaran, A.S.: Harnessing the power of generative artificial intelligence (genai) in governance, risk management, and compliance (grc). *International Research Journal of Engineering Science Technology and Innovation* **11**, 11 (05 2024)
- [7] Khan, M.I., Arif, A., Raza, A., Khan, A.: The most recent advances and uses of ai in cybersecurity (04 2025)
- [8] Krumay, B., Bernroider, E.W.N., Walser, R.: Evaluation of cybersecurity management controls and metrics of critical infrastructures: A literature review considering the nist cybersecurity framework. In: Gruschka, N. (ed.) *Secure IT Systems*. pp. 369–384. Springer International Publishing, Cham (2018)
- [9] Li, H., Guo, D., Fan, W., Xu, M., Huang, J., Meng, F., Song, Y.: Multi-step jailbreaking privacy attacks on chatgpt (2023), <https://arxiv.org/abs/2304.05197>
- ¹European Union, “The EU Artificial Intelligence Act”, 2024.
- ²NIST, “Towards a Standard for Identifying and Managing Bias in Artificial Intelligence”, 2022.
- [10] Mahadevkar, S.V., P.S.K.K.e.a.: Exploring ai-driven approaches for unstructured document analysis and future horizons (2024). <https://doi.org/https://doi.org/10.1186/s40537-024-00948-z>
- [11] Mauri, L., Damiani, E.: Modeling threats to ai-ml systems using stride. *Sensors* **22** (09 2022). <https://doi.org/10.3390/s22176662>
- [12] Morovat, K., Panda, B.: A survey of artificial intelligence in cybersecurity. In: 2020 International Conference on Computational Science and Computational Intelligence (CSCI). pp. 109–115 (2020). <https://doi.org/10.1109/CSCI51800.2020.00026>
- [13] NIST: Artificial intelligence risk management framework: Generative artificial intelligence profile (2024). <https://doi.org/https://doi.org/10.6028/NIST.AI.600-1>
- [14] Obisesan, S.: Integrating artificial intelligence and cybersecurity frameworks: Challenges and opportunities in e-commerce cybersecurity management (2024). <https://doi.org/10.13140/RG.2.2.34780.91527>
- [15] Pereira, V., Hadjielias, E., Christofi, M., Vrontis, D.: A systematic literature review on the impact of artificial intelligence on workplace outcomes: A multi-process perspective. *Human Resource Management Review* **33**(1), 100857 (2023). <https://doi.org/https://doi.org/10.1016/j.hrmr.2021.100857>
- [16] PS, D.V.: How can we manage biases in artificial intelligence systems – a systematic literature review. *International Journal of Information Management Data Insights* **3**(1), 100165 (2023). <https://doi.org/https://doi.org/10.1016/j.ijime.2023.100165>
- [17] Rahul Joshi, Krishna Pandey, S.K.: Generative ai: A transformative tool for mitigating risks for financial frauds (2025). <https://doi.org/https://doi.org/10.1002/9781394271078.ch7>
- [18] Roshani, M.A., Zhou, X., Qiang, Y., Suresh, S., Hicks, S., Sethuraman, U., Zhu, D.: Generative llm powered conversational ai application for personalized risk assessment: A case study in covid-19 (2024), <https://arxiv.org/abs/2409.15027>
- [19] Rychkov, V., Picoco, C., Caleca, E.: Impact of generative ai (large language models) on the pra model construction and maintenance, observations (2024), <https://arxiv.org/abs/2406.01133>
- [20] Shengye Wan, Cyrus Nikolaidis, D.S.D.M.J.C.J.G.M.B.S.C.S.W.S.D.V.I.Y.L.J.S.: Cyberseceval 3: Advancing the evaluation of cybersecurity risks and capabilities in large language models (2024)
- [21] Sjekavica, M., Knežević, D., Knežević, T., Meštrović, H.: Artificial intelligence in risk management system on infrastructure projects. pp. 208–214 (01 2023). <https://doi.org/10.3311/CCC2023-028>
- [22] Union, E.: European data act (2023), https://eur-lex.europa.eu/legal-content/EN/TXT/PDF/?uri=OJ:L_202302854
- [23] Vadisetty, R., Polamarasetti, A.: Generative ai-driven distributed cybersecurity frameworks for ai-integrated global big data systems. In: 2024 International Conference on Emerging Technologies and Innovation for Sustainability (EmergIN). pp. 595–600 (2024). <https://doi.org/10.1109/EmergIN63207.2024.10961616>
- [24] Verma, A., Sankhyayan, S., Jawanda, K., Tandon, S.: Generative artificial intelligence and cybersecurity risks: Issues and challenges. In: Fong, S., Dey, N., Joshi, A. (eds.) *ICT Analysis and Applications*. pp. 321–327. Springer Nature Singapore, Singapore (2025)
- [25] Wei, J., Wang, X., Schuurmans, D., Bosma, M., Ichter, B., Xia, F., Chi, E., Le, Q., Zhou, D.: Chain-of-thought prompting elicits reasoning in large language models (2023), <https://arxiv.org/abs/2201.11903>
- [26] Zhen Ling Teo, Chrystie Wan Ning Quek, J.L.Y.W.D.S.W.T.: Cybersecurity in the generative artificial intelligence era. *Asia-Pacific Journal of Ophthalmology* **13**(4), 100091 (2024). <https://doi.org/https://doi.org/10.1016/j.apjo.2024.100091>
- [27] Zou, A., Wang, Z., Carlini, N., Nasr, M., Kolter, J.Z., Fredrikson, M.: Universal and transferable adversarial attacks on aligned language models (2023), <https://arxiv.org/abs/2307.15043>